

Fuzz Testing Triage Procedure

Revision

Version 1
6/26/26 2:56 PM

Author

Charles Wilson

Abstract

This document describes the procedure used to perform the **triage** activity described in the **AVCDL** ^[1] secondary document **Fuzz Testing Report** ^[2].

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to have runtime-specific, cybersecurity-related feedback in the development of software for use within safety-critical, cyber-physical systems.

Note: Within the context of this document, the terms ***security*** and ***cybersecurity*** are used interchangeably. It is presumed that the term ***security*** is being used in reference to ***cybersecurity*** and not ***physical security***.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Audience

The audience of this document is the cybersecurity practitioner who will be conducting cybersecurity-specific fuzz testing.

Completeness of Output

Since fuzz testing is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the fuzz testing SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

Disposition of Output

Once completed, the generated output should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of cybersecurity-specific fuzz testing. Further, that the reader has read and understood the following:

- **Fuzz Testing Report**
- **Fuzz Testing – Establish Settings Procedure** [\[3\]](#)
- **Fuzz Testing – Create Test Procedure** [\[4\]](#)
- **Fuzz Testing – Perform Testing Procedure** [\[5\]](#)
- **Report Generation** [\[9\]](#)

Prerequisites – Development SME

Qualifications

It is required that the development SME is both a qualified and trained development SME with expertise in the element under consideration.

Note: The specific qualifications and training of development SMEs necessary to assert expertise in providing accurate information regarding the element under consideration is outside the scope of this document.

Note: The development group is responsible for determining and making available the appropriate SME for the triage of the element under consideration.

Knowledge

It is required that the development SME have expertise in the element under consideration.

Prerequisites – Fuzz Testing SME

Qualifications

It is required that the fuzz testing SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in the **NCWF Roles - Security Architect** section of the **AVCDL Background Material** elaboration document [\[8\]](#).

Knowledge

It is required that the fuzz testing SME understands the purpose of cybersecurity-specific fuzz testing.

Background Information

It is required that the fuzz testing SME has read and understands the following documents:

- **Fuzz Testing Report**
- **Fuzz Testing – Establish Settings Procedure**
- **Fuzz Testing – Create Test Procedure**
- **Fuzz Testing – Perform Testing Procedure**
- **Report Generation**

Additionally, that the fuzz testing SME has taken the trainings relevant to this activity.

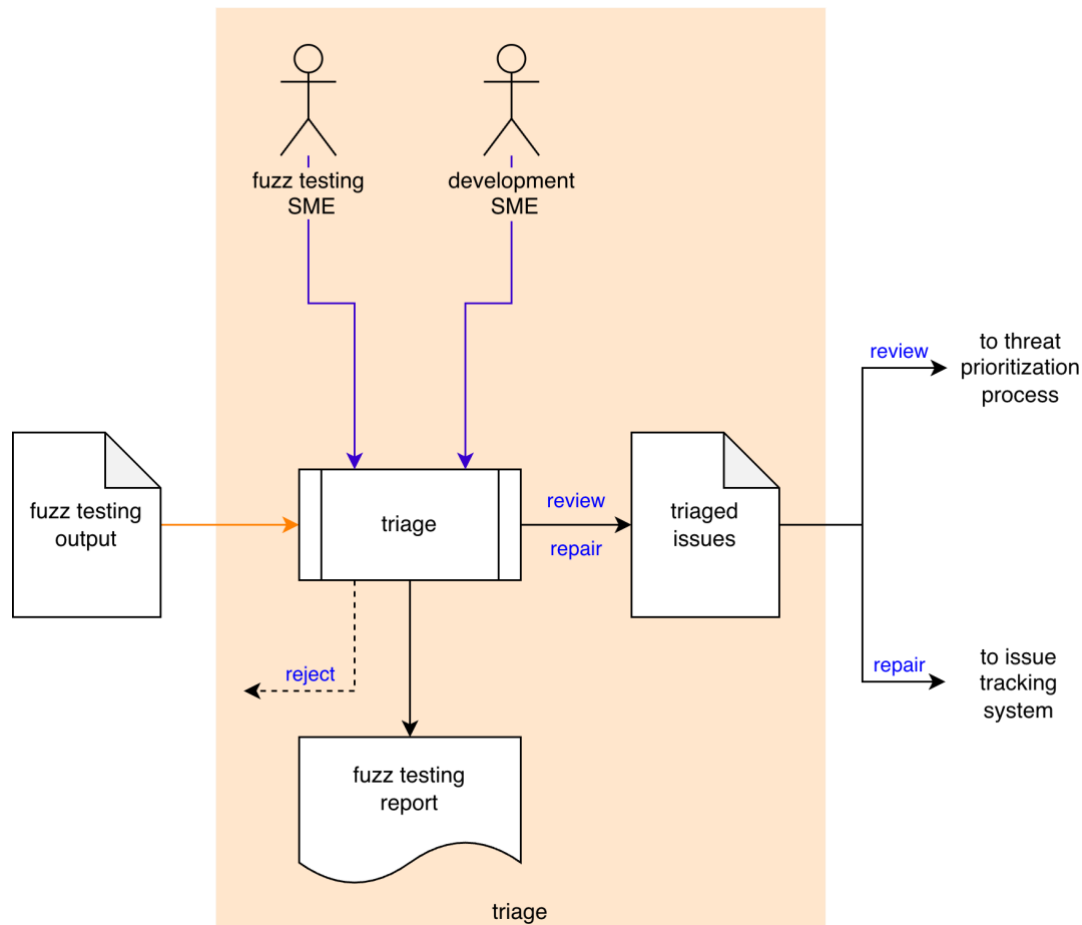
Prerequisites – Input Materials

It is required that the fuzz testing SME acquire all relevant documentation related to the tool under consideration necessary to complete the procedure.

It is required that the development group provide all relevant documentation related to the element under consideration necessary to complete the procedure.

Triage Activity

The workflow diagram for the **triage** activity of the **Fuzz Testing** process is shown below.



The **Fuzz Testing SME** and the **Development SME** triage the **Fuzz Testing Output** to identify any anomalous behavior needing review or repair. **Triaged Issues** are sent to the threat prioritization process [7]. False positives are rejected and require that the **Element Fuzz Test** created during the create test activity be updated to address the issue. A **Fuzz Testing Report** will be generated.

Note: Depending on the element scope and nature of the identified issue, issues may be entered directly into the issue tracking system.

Note: The recommended form of the **Triaged Issues** artifact is JSON-encoded Static Analysis Results Interchange Format (**SARIF**). This document assumes SARIF version 2.1.0 [6] or later.

Methodology

The purpose of triage is first and foremost to eliminate those issues which are false positives. A secondary goal is to identify “must fix” issues. What remains is put into the threat prioritization process.

There are three options when dispositioning an issue. These are:

Reject

This disposition should be assigned when the issue is determined to be a false positive. The Fuzz Testing SME should update the test and verify that the issue is no longer flagged.

Review

This disposition should be assigned when the issue is determined to require additional review via the threat prioritization process.

Repair

This disposition should be assigned when the issue is clearly one which requires mitigation. These issues should be directly entered into the issue tracking system. If the issue comes from a test which resulted in an expected program termination, it probably fits into this category.

Fuzz Testing Triage Template

The triage activity may be documented using the **AVCDL fuzz testing triage template** Microsoft Excel workbook [\[4\]](#).

Note: Other forms of documentation are permissible so long as they provide the information laid out in this document.

There are five sheets in the workbook. They are:

- [Cover sheet](#)
- [Revision history](#)
- [Reference documents](#)
- [Triage determination](#)
- [Legend](#)

These will be addressed in turn.

Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks are attached to some of the cells which also enables the use of dropdown lists.

Cover Sheet

The **cover sheet** of the workbook is shown below:

Fuzz Testing - Triage							
Element Name	Element Name						
Element Scope	Element Scope						
Vendor Name	Vendor Name						
Security SME	Security SME						
Development SME	Development SME						
Date	27-Aug-2000						
Model Revision	1						

Fields to be completed are shown in **red**.

Element Name

The **element name** is the element whose fuzz testing issues are being triaged.

Element Scope

The scope of the element is left to the discretion of the customer. Examples of element scopes include system, sub-system, component, component software (non-OS), and component OS.

Note: In this context, **the customer** refers to the entity requiring the activity.

Vendor Name

This is the name of the vendor responsible for the element under consideration.

Security SME

This is the fuzz testing subject matter expert triaging the fuzz testing output.

Development SME

This is the development subject matter expert providing information about the element.

Date

This is the date when the element's fuzz testing triage was created or updated. The date should be updated whenever the document is updated.

Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

Revision History

The **revision history** sheet of the workbook is shown below:

Revision History		
Revision	Author	Description
1		initial revision

Revision

The **revision** corresponds to that listed on the cover sheet.

Author

The **author** corresponds to the security SME listed on the cover sheet.

Description

This is a brief description of changes made to the fuzz testing triage since it was last updated.

Reference Documents

Note: These references are those necessary for the creation of the element's **fuzz testing output** triage.

Note: Reference to the element's fuzz testing output should be included.

The **references** sheet of the workbook is shown below:

Reference Documents		
Name	Description	Location

Name

This is the name of the document being referenced.

Description

This is a brief description of the document being referenced.

Location

This is the location of the document being referenced. It may be a physical location or a URL.

Triage Determination

The **triage determination** sheet of the workbook is shown below:

Triage Determination				
issue ID	determination	preliminary severity	justification	notes

Issue ID

This is the unique element fuzz testing issue ID.

Determination

This is the determination of the issue's triage. It may be one of the following:

- reject
- review
- repair

Note: The meanings of these were covered earlier in this document.

Preliminary Severity (optional)

If the determination is that the issue is valid, a **preliminary severity** (rank / likelihood) may be provided.

Note: The **preliminary severity** value set is not provided as it is highly specific to the organizational and domain. A discussion of quantized rank values can be found in the **Ranked / Risked Threat Report** ^[10] ACVDL secondary document.

Justification

This is the justification for the selected determination.

Note: If the determination is that the issue is **reject**, a justification is required.

Notes

This is a general notes field.

Legend

The **legend** sheet of the workbook is shown below:

determination
reject
review
repair

The **legend** sheet information is used to make the completion of the document easier by providing dropdown lists for common values. It also ensures that spelling errors do not creep into the generated material.

Note: The legend sheet should not be edited. If an unlisted value is required, the template should be separately revised.

Fuzz Testing Report

The **Fuzz Testing Report** is the human-readable record of the activity. It is intended to be a standalone document for audit purposes. It's preferred embodiment for storage in the DMS is PDF. The content of the report is covered in the **Fuzz Testing Report** AVCDL secondary document.

Note: If possible, it is recommended that the fuzz testing report be generated programmatically. Creating the report from the JSON-encoded SARIF for the **Identified Issues** file makes this process much easier.

Note: Although all issues contained in the **Fuzz Testing Output** may be included in the report, it is recommended to restrict the report to only those items which are not rejected. Additionally, it is recommended that the items chosen for **review** and **repair** be in separate sections.

Exit Criteria

This procedure is considered complete once the **Fuzz Testing Report** has been entered into the organization's DMS as a document of record.

Note: The processes and procedures for entering documents into the DMS, or the updating thereof, are outside the scope of this document.

References

1. **AVCDL** (AVCDL primary document)
2. **Fuzz Testing Report** (AVCDL secondary document)
3. **Fuzz Testing – Establish Settings Procedure** (AVCDL tertiary document)
4. **Fuzz Testing – Create Test Procedure** (AVCDL tertiary document)
5. **Fuzz Testing – Perform Testing Procedure** (AVCDL tertiary document)
6. **Static Analysis Results Interchange Format (SARIF) Version 2.1.0**
<https://docs.oasis-open.org/sarif/sarif/v2.1.0/os/sarif-v2.1.0-os.pdf>
7. **Threat Prioritization Plan** (AVCDL secondary document)
8. **AVCDL Background Material** (AVCDL elaboration document)
9. **Report Generation** (AVCDL elaboration document)